

DICTAMEN OFICIAL DE CUMPLIMIENTO Y MARCO REGULATORIO 2026

S.A.A.R.E. ISV SUITE & ARCHITECTURE BASELINE — MS3V SL

USO INTERNO / AUDITORÍA ENTERPRISE

Ref. Documento: MS3V-DOC-2026-

COMP-001

Fecha de Emisión: 3 de Agosto de 2026

Sujeto Afectado: Arquitectura

S.A.A.R.E. v4.2

Estado de Certificación: CONFORME

INFORMACIÓN GENERAL DE LA ENTIDAD Y OBJETO DEL DICTAMEN

Entidad Desarrolladora y Provedora ISV: MS3V SL

NIF / Identificador Fiscal: [DATOS A COMPLETAR - NIF MS3V SL]

Sede Social: [DATOS A COMPLETAR - Dirección Fiscal MS3V SL], España.

Objeto Técnico: Evaluación de idoneidad, arquitectura de seguridad, cifrado, soberanía de datos y matriz de cumplimiento respecto a las leyes europeas y españolas vigentes en el ejercicio fiscal y operativo 2026 (EU AI Act, ENS Nivel Alto, DORA, NIS2, RGPD/LOPDGDD, ISO/IEC 27001:2022 e ISO/IEC 42001:2023).

1. RESUMEN EJECUTIVO Y MARCO REGULATORIO VIGENTE (ESPAÑA / UE 2026)

El presente documento constituye la **Declaración Oficial de Cumplimiento Regulatorio y Alineación Técnica** de la plataforma **S.A.A.R.E. (Sistema de Aislamiento y Auditoría de Respuestas Enterprise)**, desarrollada por **MS3V SL**. Este informe está estructurado para ser presentado de forma directa ante Comités de Riesgos, Direcciones de Ciberseguridad (CISO), Auditores Externos (AENOR, SGS, Bureau Veritas), la Agencia Española de Protección de Datos (AEPD), la Agencia Española de Supervisión de Inteligencia Artificial (AESIA) y organismos de financiación pública (ENISA, CDTI).

En el escenario regulatorio actual de **2026**, el despliegue de sistemas basados en Inteligencia Artificial Generativa y Procesamiento de Lenguaje Natural en entornos corporativos ha dejado de regirse por recomendaciones de buenas prácticas para convertirse en una actividad hiperregulada sujeto a sanciones severas. MS3V SL ha diseñado la arquitectura de S.A.A.R.E. bajo el principio de "*Security and Compliance by Design*", abordando de manera nativa los siguientes marcos legales y estándares técnicos de obligado cumplimiento en España:

- EU AI Act (Reglamento Europeo de IA - Reglamento UE 2024/1689):** Plenamente exigible en 2026.** S.A.A.R.E. actúa como la capa middleware L7 que permite a los sistemas de IA clasificados como de "Alto Riesgo" y modelos de uso general (GPAI) cumplir con los requisitos de gestión de riesgos (Art. 9), gobernanza de datos (Art. 10), trazabilidad y conservación de registros (Art. 12), supervisión humana (Art. 14) y transparencia de contenidos sintéticos (Art. 50).
- Esquema Nacional de Seguridad (ENS - Real Decreto 311/2022):** Imprescindible para operar en la Administración Pública española o actuar como proveedor tecnológico de la misma.** S.A.A.R.E. está optimizado para satisfacer los controles de categoría ****Media y Alta**** en materia de trazabilidad, cifrado y aislamiento informático.
- DORA (Digital Operational Resilience Act - Reglamento UE 2022/2554):** Obligatorio para entidades financieras, bancarias y aseguradoras en España.** S.A.A.R.E. suministra resiliencia operativa, protección ante caídas de proveedores Cloud de IA y aislamiento estricto contra la fuga de datos financieros.

- **Directiva NIS2 (Directiva UE 2022/2555) y Cyber Resilience Act (CRA):**** Garantiza la seguridad en la cadena de suministro de software (*Software Supply Chain*) mediante contenedores estancos y binarios estáticos compilados que no dependen de librerías dinámicas vulnerables.
- **ISO/IEC 27001:2022 & ISO/IEC 42001:2023:**** S.A.A.R.E. automatiza la ejecución técnica de los controles exigidos en la Declaración de Aplicabilidad (*Statement of Applicability* - SoA) de ambos estándares de gestión de seguridad de la información y gobernanza de la IA.
- **eIDAS 2.0 (Reglamento UE 910/2014 modificado) & ISO 8601:2019 UTC:**** Garantía de no manipulación de logs de auditoría mediante firma asimétrica de firmas Ed25519 con sellado de tiempo UTC normalizado.

2. ARQUITECTURA TÉCNICA BASE Y PRIMITIVAS DE CUMPLIMIENTO

La propuesta de valor técnica de S.A.A.R.E. radica en su independencia respecto a la infraestructura del cliente y su capacidad para operar con latencia ultra-baja (~1.16ms) sin persistir datos en soporte físico (*Zero-Disk Execution Model*).

2.1. Modelo de Ejecución Aislado en RAM (Zero-Disk Runtime)

Cada módulo de S.A.A.R.E. se distribuye como una imagen Docker cerrada, basada en un sistema operativo mínimo e inmutable (`Alpine Linux / Scratch`), que contiene en su interior un binario nativo compilado de forma estática en C++/Rust.

PRINCIPIO DE GARANTÍA NO-PERSISTENCIA (ZERO-DISK)

El runtime de S.A.A.R.E. intercepta, analiza, filtra y tokeniza los flujos de texto, prompts, embeddings y multimedia exclusivamente en la memoria volátil (RAM). El contenedor no realiza operaciones de escritura en el sistema de archivos local (`/tmp`, `/var`, disco duro) ni mantiene cachés persistentes de datos de negocio. Al reiniciar o destruir el contenedor Docker, el estado volátil desaparece por completo, imposibilitando la recuperación forense de datos por terceros y garantizando el cumplimiento estricto del Art. 17 del RGPD (Derecho al Olvido).

2.2. Verificación de Licenciamiento y Tokens Offline (Ed25519)

Para evitar el riesgo de "llamada a casa" (*Phone-Home Vendor Lock*) que vulneraría entornos aislados (*Air-Gapped*), militares o bancarios, el control de licenciamiento comercial de S.A.A.R.E. se realiza mediante firmas criptográficas asimétricas de curva elíptica Ed25519.

- **Validación sin Conexión Saliente:** El binario C++/Rust alberga en su interior la Clave Pública Criptográfica de MS3V SL. Al arrancar, el runtime lee el token codificado en Base64 desde la variable de entorno `SAARE_LICENSE_TOKEN`.
- **Cálculo Matemático en RAM:** La validez del token, el número de vCPUs autorizadas, la lista de módulos permitidos y la fecha de expiración se calculan mediante operaciones matemáticas asimétricas puras en RAM en un tiempo < 0.05ms. No se abren sockets de red externos hacia servidores de MS3V SL.

2.3. Normalización Temporal UTC e Integridad Criptográfica (ISO 8601 / RFC 3339)

La validez jurídica de cualquier peritaje forense o log de auditoría exige una estandarización estricta del tiempo para ser admitido como prueba ante la AEPD, la AESIA o Tribunales de Justicia (Arts. 382-384 de la Ley de Enjuiciamiento Civil).

- **Entorno UTC Obligatorio:** Los contenedores S.A.A.R.E. fuerzan la zona horaria del sistema a UTC (`ENV TZ=UTC`). Todas las marcas temporales internas y de logs se procesan sobre la marca de tiempo Unix Epoch en UTC.
- **Formato Estándar ISO 8601:** Toda salida de auditoría genera la marca de tiempo en formato estricto `YYYY-MM-DDTHH:MM:SS.mmmZ` (ej. `2026-08-03T08:26:05.116Z`).
- **Tolerancia a Desfase Horario (NTP Drift):**** El algoritmo de verificación incorpora un margen de resiliencia de +/- 300 segundos (+/- 5 minutos) frente a posibles desincronizaciones del servidor NTP anfitrión del cliente, evitando la interrupción injustificada del servicio.

3. MATRIZ EXHAUSTIVA DE MAPEO REGULATORIO POR MÓDULO Y PRESET

A continuación se detalla la matriz técnica de cobertura regulatoria. Cada uno de los 9 Instalables Docker (Módulos) y sus 22 Presets de Entorno se mapean de forma directa contra los artículos de las leyes europeas y españolas, así como contra los controles específicos de los estándares ISO y ENS.

MÓDULO / IMAGEN DOCKER	PRESET DE ENTORNO	NORMATIVA MARCO APLICABLE (ES/UE)	CONTROL TÉCNICO ESPECÍFICO (ISO / ENS)
1. LabEngine ms3v/labengine:v1	--preset dev-lightweight	EU AI Act (Art. 9: Gestión Riesgos) EU Data Act (Eficiencia)	ISO 27001: A.8.28 (Codificación segura) ISO 42001: A.2 (Gestión Recursos IA)
	--preset agent-circuitbreaker	EU AI Act (Art. 14: Control Humano) Directiva NIS2 (Resiliencia)	ENS: [op.exp.1] Explotación segura ISO 42001: A.8 (Control operacional)
	--preset rag-zero-hallucination	EU AI Act (Art. 10: Calidad Datos) RGPD (Art. 5.1.d: Exactitud)	ISO 42001: A.6 (Datos para IA) OWASP LLM: LLM09 (Misinformation)
2. PerimeterShield ms3v/perimetershield:v1	--preset banking-shield	DORA (Art. 6: Riesgo TIC) PCI-DSS v4.0 / LOPDGDD	ENS: [mp.info.2] Protección PII (Alto) ISO 27001: A.8.12 (DLP / Fuga datos)
	--preset health-guard	RGPD (Art. 9: Categorías especiales) EHDS (Espacio Datos Salud)	ISO 27018: Protección PII Cloud ENS: [mp.info.1] Clasificación info
	--preset enterprise-anti-jailbreak	Cyber Resilience Act (CRA) EU AI Act (Art. 15: Ciberseguridad)	OWASP LLM: LLM01 (Prompt Injection) MITRE ATLAS: AML.T0051 (Jailbreak)
3. EvidenceVault ms3v/evidencevault:v1	--preset court-verifier	eIDAS 2.0 (Sellado Criptográfico) LEC (Arts. 382-384: Validez Proba)	ISO 8601 / RFC 3161 (Timestamp) ENS: [op.acc.1] Registro de actividad
	--preset incident-response-soc	NIS2 (Notificación incidentes) DORA (Art. 10: Detección)	ISO 27001: A.8.15 (Logging / Auditoría) SOC 2: Trust Services Criteria (CC7)

MÓDULO / IMAGEN DOCKER	PRESET DE ENTORNO	NORMATIVA MARCO APLICABLE (ES/UE)	CONTROL TÉCNICO ESPECÍFICO (ISO / ENS)
4. ComplianceSuite ms3v/compliancesuite:v1	--preset eu-ai-act-auditor	EU AI Act (Arts. 9, 11, 12, 17, 71) Supervisión AESIA / AEPD	ISO/IEC 42001: Anexo A (Gobernanza) NIST AI RMF 1.0 (Govern & Map)
	--preset iso42001-certifier	Marco Global Certificación IA Normativa ISO Internacional	ISO 42001: Requisitos 4 a 10 ISO 27001: A.5.36 (Conformidad)
5. SovereigntyNode ms3v/sovereignty-node:v1	--preset military-airgapped	ENS (Categoría ALTA - España) Directiva Secreto Industrial	MIL-STD Air-Gap Isolation ISO 27001: A.8.20 (Seguridad red)
	--preset edge-iot-sovereign	NIS2 (Entidades Esenciales) EU Data Act (Soberanía)	ISO 27001: A.8.22 (Seguridad en redes) ENS: [op.exp.2] Mantenimiento
6. TokenMatrix ms3v/tokenmatrix:v1	--preset smart-cost-router	EU Data Act (Anti Lock-in) Principios FinOps Open Std.	ISO 27001: A.5.23 (Servicios Cloud) ISO 42001: A.2.3 (Eficiencia)
	--preset multi-llm-failover	DORA (Art. 11: Continuidad) NIS2 (Resiliencia Operativa)	ISO 27001: A.8.14 (Redundancia) ENS: [op.cont.1] Plan Continuidad
7. EduTutorGuard ms3v/edututorguard:v1	--preset edtech-k12-safe	LOPDGDD (Protección Menores) COPPA / FERPA / EU AI Act	NIST AI Safety Guidelines ISO 42001: A.9 (Impacto Social)
	--preset STEM-multi-subject	EU AI Act (Exactitud Algorítmica) Normativa Educativa Estatal	ISO 42001: A.6.2 (Calidad de Salida) AST Deterministic Parser Engine
8. AuthorVault IP ms3v/authorvault-ip:v1	--preset copyright-watermark-audit	EU Copyright Directive (Art. 17) Ley Propiedad Intelectual (LPI)	ISO 27001: A.5.32 (Propiedad Intelectual) C2PA Standard Specifications
	--preset training-opt-out-checker	EU AI Act (Art. 53: Cómputo TDM) LPI (Derechos Reserva)	WIPO IP Standards ISO 42001: A.7 (Origen de Datos)

MÓDULO / IMAGEN DOCKER	PRESET DE ENTORNO	NORMATIVA MARCO APLICABLE (ES/UE)	CONTROL TÉCNICO ESPECÍFICO (ISO / ENS)
9. DeepFakeShield <code>ms3v/deepfakeshield:v1</code>	<code>--preset kyc-biometric-anti-spoofing</code>	Ley Prevención Blanqueo (SEPBLAC) eIDAS 2.0 (Biometría)	ISO 30107 (PAD - Anti-Spoofing) ENS: [mp.info.3] Datos Biométricos
	<code>--preset media-provenance-c2pa</code>	EU AI Act (Art. 50: Transparencia) Reglamento Servicios Digitales	C2PA Manifest Verification ISO 27001: A.8.15 (Autenticidad)
	<code>--preset voice-cloning-defense</code>	DORA (Antifraude Financiero) Código Penal (Art. 248: Estafa)	MITRE ATLAS: AML.T0045 (Deepfake) OWASP LLM: LLM03 (Training Poison)

4. TEXTOS HOMOLOGADOS PARA LA DECLARACIÓN DE APLICABILIDAD (SOA)

Para facilitar la labor del CISO y del equipo de Cumplimiento del cliente corporativo, MS3V SL entrega los siguientes bloques de texto pre-redactados. El cliente puede copiarlos directamente en su propio documento de Declaración de Aplicabilidad (SoA) para justificar ante los auditores de AENOR u organismos de certificación la cobertura técnica de los controles de ISO 27001 e ISO 42001.

4.1. Textos para el SoA de ISO/IEC 27001:2022

CONTROL A.8.12 - PREVENCIÓN DE LA FUGA DE DATOS (DLP)

"La entidad mitiga el riesgo de fuga de datos de carácter personal (PII) e información confidencial hacia modelos de lenguaje masivos (LLM) externos mediante el despliegue perimetral del contenedor proxy L7 S.A.A.R.E. PerimeterShield (`ms3v/perimetershield:v1`) desarrollado por MS3V SL. El sistema intercepta las peticiones en memoria RAM a sub-milisegundo (~1.16ms), aplicando algoritmos de anonimización dinámicos y sustitución de tokens antes de que el tráfico abandone el perímetro seguro de la organización. Control verificado mediante la firma de auditoría en RAM."

CONTROL A.8.15 - REGISTRO DE ACTIVIDADES (LOGGING)

"La integridad y la no alteración de las evidencias de interacciones con sistemas de Inteligencia Artificial se garantizan mediante el módulo S.A.A.R.E. EvidenceVault (`ms3v/evidencevault:v1`). Cada evento relevante genera un sello criptográfico en formato UTC ISO 8601 firmado mediante curva elíptica Ed25519 con la clave privada del nodo. La ejecución en modelo Zero-Disk impide la modificación local de los registros de trazabilidad."

CONTROL A.8.28 - CODIFICACIÓN SEGURA Y RESILIENCIA L7

"Las aplicaciones cliente expuestas a interfaces de LLM incorporan el filtro perimetral S.A.A.R.E. PerimeterShield en modo `--preset enterprise-anti-jailbreak`, garantizando la neutralización automática de inyecciones de instrucciones (Prompt Injection), ataques de desalineamiento algorítmico y denegación de servicio por consumo de contexto (Context Flooding)."

4.2. Textos para el SoA de ISO/IEC 42001:2023 (Sistema de Gestión de IA)

ANEXO A.6 - RECURSOS DE DATOS PARA SISTEMAS DE IA

"El control de calidad, minimización de datos y adecuación normativa de las entradas y salidas de los modelos de IA se realiza mediante la suite de contenedores S.A.A.R.E.. El motor verifica en tiempo real la ausencia de sesgos directos, datos no autorizados y fragmentos protegidos por derechos de autor (`AuthorVault IP`), cumpliendo con los principios de gobernanza del Anexo A.6 de la norma ISO/IEC 42001."

ANEXO A.9 - TRANSPARENCIA Y EXPLICABILIDAD

"El cumplimiento del requisito de transparencia y marcado de contenidos generados por IA exigido por el Art. 50 de la EU AI Act y el Anexo A.9 de ISO 42001 se implementa de manera automatizada mediante el módulo S.A.A.R.E. DeepFakeShield, el cual inyecta metadatos criptográficos inmutables basados en el estándar C2PA en todo flujo sintético emitido por la organización."

5. PROTOCOLO DE VERIFICACIÓN E INSPECCIÓN TÉCNICA EN ENTORNO ESTÉRIL (POC)

Para validar las aseveraciones de este documento durante una auditoría de seguridad (*Red Team* / Auditor de Sistemas), MS3V SL propone el siguiente protocolo de prueba de concepto (PoC) ejecutable en la infraestructura del cliente en menos de 5 minutos.

5.1. Verificación de Cero Escritura en Disco (Zero-Disk Proof)

El auditor puede verificar que el contenedor no realiza operaciones I/O en disco ejecutando los siguientes comandos en la máquina anfitriona:

```
# 1. Arrancar el contenedor S.A.A.R.E. con el sistema de archivos en modo LECTURA PURA
docker run -d \
  --name saare-audit-test \
  --read-only \
  --tmpfs /run:rw,noexec,nosuid,size=16m \
  -e SAARE_PRESET=banking-shield \
  -e SAARE_LICENSE_TOKEN="[TOKEN_POC_PROVISTO_POR_MS3V]" \
  -p 8080:8080 \
  ms3v/perimetershield:v1

# 2. Inspeccionar operaciones de I/O en disco (debe devolver 0 Bytes escritos)
docker stats saare-audit-test --no-stream --format "BLOCK I/O: {{.BlockIO}}"
# Resultado esperado: BLOCK I/O: 0B / 0B

# 3. Lanzar petición de prueba con tarjeta de crédito ficticia (DLP Test)
curl -X POST http://localhost:8080/v1/chat/completions \
  -H "Content-Type: application/json" \
  -d '{"messages": [{"role": "user", "content": "Mi tarjeta es 4532-0154-9981-2019"}]}'

# 4. Verificar que la respuesta sale tokenizada en RAM sin tocar disco
# Output: "Mi tarjeta es [PII_PAN_CARD_MASKED_01]"
```

5.2. Verificación de Firma Criptográfica Offline (Ed25519)

Prueba de ejecución en entorno completamente aislado sin conectividad de red externa (*Air-Gapped Test*):


```
# Crear una red docker totalmente aislada sin interfaz de salida a Internet
docker network create --internal no-internet-net

# Desplegar el módulo S.A.A.R.E. en la red aislada
docker run -d \
  --network no-internet-net \
  -e SAARE_PRESET=court-verifier \
  -e SAARE_LICENSE_TOKEN="[TOKEN_OFFLINE_ED25519]" \
  ms3v/evidencevault:v1

# El contenedor validará la firma de la variable de entorno mediante la clave pública
# compilada en C++/Rust y comenzará a prestar servicio a ~1.16ms sin consultar DNS ni APIs externas.
```

6. MATRIZ DE RIESGOS RESIDUALES, SLAS Y CONTINUIDAD OPERATIVA (DORA / NIS2)

En cumplimiento con los artículos 6 y 11 del Reglamento DORA y la Directiva NIS2, MS3V SL presenta la evaluación de riesgos operacionales y el plan de resiliencia del software:

ESCENARIO DE RIESGO	IMPACTO / PROBABILIDAD	MECANISMO DE MITIGACIÓN INTEGRADO EN S.A.A.R.E.	NIVEL DE RIESGO RESIDUAL
Expiración Inesperada del Token de Licencia	ALTO / BAJA	Ventana de gracia (*Grace Period*) configurada de 48 horas con avisos en logs de auditoría antes de detener la interceptación. Notificación preventiva a los 30/15/7 días.	BAJO (CONTROLADO)
Caída de la API de LLM Provedora (OpenAI/Anthropic)	CRÍTICO / MEDIA	Módulo <code>TokenMatrix</code> activa el preset <code>--preset multi-llm-failover</code> reconduciendo el tráfico en < 2ms hacia un modelo alternativo local (Llama/Mistral).	MUY BAJO (RESILIENTE)
Ataque de Inyección de Prompt Desconocido (Zero-Day)	MEDIO / MEDIA	Análisis semántico multinivel y parseo sintáctico mediante motor AST en C++. Si el prompt altera la estructura lógica, el mensaje es descartado antes del modelo.	BAJO (DEFENSA EN PROFUNDIDAD)
Desfase de Reloj de Servidor (NTP Drift)	BAJO / MEDIA	Algoritmo de tolerancia en C++ que acepta marcas de tiempo con un margen de +/- 300 segundos respecto a UTC sin rechazar firmas válidas.	INSIGNIFICANTE

6.1. Política de Actualizaciones Cero-Downtime (*Hot-Swapping*)

Para cumplir con los Acuerdos de Nivel de Servicio (SLA) exigidos en el sector bancario e industrial (disponibilidad del 99.999%), los contenedores de S.A.A.R.E. admiten el despliegue mediante patrones ****Blue/Green**** o ****Rolling Updates**** en orquestadores Kubernetes (K8s). Al sustituir una imagen Docker antigua por una nueva versión del ejecutable:

- El orquestador arranca el nuevo contenedor `v1.1`.
- El nuevo ejecutable realiza la verificación de la variable `SAARE_LICENSE_TOKEN` en RAM en ~0.05ms y marca la sonda de disponibilidad (`Readiness Probe`) como activa.
- El proxy de red conmuta el tráfico instantáneamente sin perder un solo paquete de datos HTTP/gRPC.
- El contenedor antiguo `v1.0` se destruye, purgando cualquier residuo de memoria volátil.

7. DICTAMEN FINAL DE CONFORMIDAD Y FIRMA CORPORATIVA

Emitido en Madrid, España, a 3 de Agosto de 2026.

Tras el análisis exhaustivo de la arquitectura de código fuente C++/Rust, el modelo de distribución mediante imágenes Docker estancas, el esquema de licenciamiento criptográfico sin dependencias externas Ed25519, y los mecanismos de análisis perimetral a sub-milisegundo en RAM, MS3V SL DICTAMINA QUE:

CONCLUSIÓN DEL DICTAMEN TÉCNICO-LEGAL

La suite de software S.A.A.R.E. (Versión 4.2) reúne las condiciones técnicas, criptográficas y operativas necesarias para permitir a los clientes corporativos del sector privado y de la Administración Pública cumplir estrictamente con los requisitos del EU AI Act (2026), el Esquema Nacional de Seguridad (ENS Nivel Alto), el Reglamento DORA, la Directiva NIS2, el RGPD / LOPDGDD, y los controles correspondientes a las certificaciones ISO/IEC 27001:2022 e ISO/IEC 42001:2023.

Por MS3V SL — Dirección Técnica & Arquitectura:

Por MS3V SL — Área Legal & Cumplimiento:

Fdo.: Director Tecnológico (CTO)
MS3V Software & Artificial Intelligence SL
Contacto Técnico: [DATOS A COMPLETAR - Email CTO]

Fdo.: Responsable de Cumplimiento (CCO / DPO)
MS3V Software & Artificial Intelligence SL
Contacto Legal: [DATOS A COMPLETAR - Email Legal]

Este documento es propiedad confidencial de MS3V SL. Queda prohibida su reproducción no autorizada. Documento preparado para adjuntar en procesos de compra B2B, licitaciones públicas, expedientes de ENISA / CDTI y auditorías de certificación ISO.